Azimi Innovation Lab
AI Architect · End-to-End Projects

جلسه 11

امنیت پایه در کد و پروژه‌ها

چطور از اطلاعات و پروژه‌های خود محافظت کنیم

ادامه مستقیم جلسات قبل — Azimi Innovation Lab

Azimi Innovation Lab
AI Architect · End-to-End Projects

اتصال به جلسات قبل: شما پروژه‌ها را می‌سازید، روی گیت‌هاب می‌گذارید و لایو می‌کنید. حالا که API، دیتابیس و دیپلوی را فهمیده‌اید، باید بدانید چطور از اطلاعات حساس محافظت کنید تا پروژه‌تان امن بماند.

۱. چرا امنیت مهم است؟

حتی پروژه‌های کوچک هم می‌توانند اطلاعات کاربران، کلیدهای API یا داده‌های دیتابیس را داشته باشند. اگر این اطلاعات لو برود، ممکن است سوءاستفاده شود. هوش مصنوعی گاهی کدهایی می‌نویسد که از نظر امنیتی ضعیف هستند، پس باید بتوانید آن‌ها را تشخیص دهید.

قانون طلایی: هیچ رمز، کلید API یا اطلاعات حساس را مستقیماً داخل کد ننویسید.

۲. متغیرهای محیطی (Environment Variables)

بهترین راه نگهداری اطلاعات حساس، استفاده از متغیرهای محیطی است. این مقادیر خارج از کد قرار می‌گیرند و در گیت‌هاب آپلود نمی‌شوند.

```
// اشتباه (هرگز این کار را نکنید)
const apiKey = "sk-1234567890abcdef";

// درست
const apiKey = process.env.API_KEY;
```

در فایل .env (که در .gitignore قرار دارد) مقدار را می‌نویسیم و در پلتفرم دیپلوی هم همان متغیر را تنظیم می‌کنیم.

۳. فایل .gitignore

این فایل به گیت می‌گوید کدام فایل‌ها را آپلود نکند. همیشه باید شامل موارد زیر باشد:

- .env و فایل‌های حاوی رمز

- node_modules
- فایل‌های لاگ
- فایل‌های سیستمی

قبل از هر push، با git status چک کنید که فایل حساسی در حال آپلود نباشد.

۴. اعتبارسنجی ورودی (Input Validation)

هر داده‌ای که از کاربر می‌آید باید بررسی شود. نباید به ورودی کاربر اعتماد کامل کرد.

```
function validateEmail(email) {
  if (!email || !email.includes("@")) {
    return false;
  }
  return true;
}

// در فرم
if (!validateEmail(userEmail)) {
  showError("ایمیل معتبر نیست");
  return;
}
```

۵. نکات مهم دیگر

- **HTTPS**: سایت لایو باید با https باشد تا ارتباط رمزنگاری شود.
- رمزهای قوی: از رمزهای ساده مثل 123456 استفاده نکنید.
- به‌روزرسانی: کتابخانه‌ها را گاهی به‌روز کنید چون نسخه‌های قدیمی ممکن است آسیب‌پذیری داشته باشند.
- حداقل دسترسی: کلید API فقط دسترسی‌های لازم را داشته باشد.

٦. اشتباهات رایج AI از نظر امنیت

- کلید API را مستقیم در کد می‌نویسد.
- فایل .env را به .gitignore اضافه نمی‌کند.
- ورودی کاربر را بدون بررسی استفاده می‌کند.
- پیام‌های خطای خیلی جزئی نشان می‌دهد که اطلاعات سیستم را لو می‌دهد.

وقتی کد AI را می‌گیرید، همیشه دنبال کلمات password، token، apiKey، secret بگردید و مطمئن شوید داخل کد هاردکد نشده باشند.

۷. تمرین‌های عملی

تمرین ۱: بررسی .gitignore

در یکی از پروژه‌های خود فایل .gitignore را باز کنید (یا از AI بخواهید یکی بسازد). ببینید آیا .env در آن هست یا نه.

تمرین ۲: پیدا کردن اطلاعات حساس

از AI بخواهید یک کد نمونه که به API وصل می‌شود بنویسد. سپس بررسی کنید آیا کلید را هاردکد کرده یا از متغیر محیطی استفاده کرده است.

تمرین ۳: اعتبارسنجی ساده

یک تابع ساده برای بررسی اینکه فیلد نام خالی نباشد بنویسید یا از AI بگیرید و آن را تست کنید.

۸. چک‌لیست پایان جلسه

- می‌دانم چرا نباید رمز را داخل کد بنویسم.
- مفهوم متغیر محیطی و .gitignore را فهمیده‌ام.
- می‌دانم ورودی کاربر باید بررسی شود.
- حداقل یک پروژه را از نظر وجود اطلاعات حساس چک کرده‌ام.
- تمرین‌ها را انجام داده‌ام.

۹. خلاصه و پل به جلسه بعد

در این جلسه اصول پایه امنیت را یاد گرفتید. حالا می‌توانید کدهای AI را از نظر امنیتی هم بررسی کنید و از اطلاعات پروژه‌های خود بهتر محافظت کنید.

جلسه بعد: کد تمیز و بهترین شیوه‌ها.

پایان جلسه 11 — Azimi Innovation Lab

حالا پروژه‌هایتان را امن‌تر می‌سازید. موفق باشید!